

SIMSHIELD ENGINEERING SPECIFICATION

Mobile Identity Fraud Risk Engine

SIM Swap, eSIM Theft, and Account Takeover (ATO) Mitigation Platform

ARCHITECTURE ROLE	TARGET PLATFORM	SECURITY STANDARD	TEST COVERAGE
Senior SDE / Security	Android + Node.js + PostgreSQL	GSMA / CAMARA / Zero-Trust	26/26 Automated Tests Pass

1 Problem Understanding

Modern mobile banking, FinTech wallets, and decentralized identity systems rely extensively on the customer’s mobile number as a primary authentication factor and recovery channel (SMS OTP). However, traditional cellular infrastructure was never architected to serve as an immutable cryptographic identity credential. This fundamental architectural mismatch exposes digital banking platforms to sophisticated, multi-stage cyberattacks:

- **Physical SIM Swap Fraud:** Adversaries use social engineering, forged documentation, or insider collusion at carrier retail outlets to port or reissue a victim's physical SIM card onto an attacker-controlled handset.
- **eSIM Profile Hijacking:** Attackers compromise telecom self-service portals to migrate digital eSIM profiles silently, intercepting cellular communication before the legitimate subscriber notices the loss of network coverage.
- **The "SMS OTP Trap":** Once the mobile number is controlled, the attacker triggers password/PIN resets, bypasses 2FA SMS challenges, registers fraudulent beneficiary accounts, and initiates large wire transfers within an emergency 15-minute window.
- **Client-Side Vulnerability (The Device Fallacy):** A mobile client app running on a compromised or swapped handset cannot be trusted to self-report fraud. If fraud verification logic resides locally on the device, malicious actors with rooted phones can hook baseband and OS APIs (e.g., TelephonyManager) to spoof safe parameters.

Core Engineering Requirement: Fraud detection cannot rely on binary assertions (e.g. `SIM_SWAP = YES`). Legitimate users change SIM cards and upgrade phones frequently. The system must evaluate a *multi-signal temporal sequence* across telecom, authentication, device, and transaction domains to calculate risk dynamically without causing unnecessary customer friction.

2 Proposed Solution

SIMShield implements a defense-in-depth, server-authoritative fraud risk mitigation platform built around the strict **"Zero-Trust Client Principle"**. The mobile application operates purely as an untrusted display, hardware biometric authenticator, and emergency killswitch, while authoritative risk scoring, multi-signal correlation, and policy enforcement execute entirely within the secure backend perimeter.

Key Architectural Tenets of the Proposed Solution:

1. **Server-Owned Risk Authority:** Real carrier signals are ingested directly via server-to-server HMAC-authenticated webhooks. The phone client never decides its own fraud score.
2. **24-Hour Sliding Correlation Window:** Security signals are evaluated across time. A single SIM replacement generates an informational warning; however, a SIM change followed immediately by a new device login and password reset escalates dynamically to Critical Takeover risk.
3. **Hardware-Backed Biometric Authentication:** Replaces fragile SMS OTP recovery with Android's native BiometricPrompt (hardware-backed fingerprint/face attestation) for out-of-band customer confirmation.

4. **Emergency "Secure My Account" Killswitch:** Instantly revokes remote sessions on all other devices, freezes wire transfers, places a cooling lock on new payees, and disables SMS recovery.

3 System Architecture

The SIMShield platform consists of three decoupled operational tiers: the Telecom Ingestion Layer, the Centralized Risk & Mitigation Service, and the Android Security Client.



4 Key Features

A. Multi-Signal Temporal Risk Engine

Correlates disparate lifecycle signals into an immutable, capped risk assessment (0–100) with machine-readable reason codes:

EVENT IDENTIFIER	WEIGHT	DOMAIN	STANDARDIZED REASON CODE
SIM_CHANGED / REPLACED	+30 pts	Telecom Physical	RECENT_SIM_CHANGE
ESIM_CHANGED / ADDED	+30 pts	Telecom Digital	RECENT_ESIM_CHANGE
NUMBER_PORTED	+25 pts	Telecom Routing	NUMBER_PORTED
NEW_DEVICE_LOGIN	+20 pts	Authentication	NEW_DEVICE / ACCOUNT_TAKEOVER_PATTERN
PASSWORD / PIN_RESET	+15 pts	Credential Recovery	PASSWORD_RESET_AFTER_SIM_CHANGE
NEW_BENEFICIARY	+15 pts	Core Banking	NEW_BENEFICIARY_AFTER_SIM_CHANGE
UNUSUAL_TRANSACTION	+20 pts	Financial Velocity	ABNORMAL_TRANSACTION

B. Automated Tiered Mitigation Policies

- **0 – 29 LOW (ALLOW)** : Standard activity. Zero customer friction.
- **30 – 49 MEDIUM (WARN_USER)** : Non-punitive warning banner. Account is not locked.
- **50 – 79 HIGH (STEP_UP_AUTH)** : Require hardware biometric or FIDO2 challenge. Sensitive actions restricted.
- **80 – 100 CRITICAL (HOLD_TRANSACTION)** : Outbound wire transfers immediately frozen; P1 fraud case opened.

C. Native Android Security Client & Biometrics

- **Hardware BiometricPrompt Integration:** Enforces genuine physical fingerprint/face sensor verification to acknowledge warnings, bypassing compromised SMS channels.
- **Emergency Account Lockdown:** Single-tap action to terminate all other remote sessions and freeze banking outflows.
- **Managed Concurrency:** Background network execution isolated on ExecutorService thread pools with UI dispatch via Handler(Looper.getMainLooper()).

D. SecOps Studio & Attack Simulator

- **Live SVG Threat Gauge:** Visualizes risk score, level, active policy, and reason tag cloud in real-time.
- **Multi-Stage ATO Replay:** Step-by-step automated simulation of the entire 5-stage attack chain with visual telemetry logging.

5 Technology Stack

LAYER / SUBSYSTEM	TECHNOLOGIES & LIBRARIES	RATIONALE & KEY CAPABILITIES
Backend Core	Node.js (v20+ ES Modules), Native HTTP	Zero-dependency, high-throughput asynchronous event processing with low memory footprint.
Persistence Tier	PostgreSQL 16, Parameterized SQL	ACID compliance, composite indexing on (user_id, timestamp DESC), JSONB audit storage.
Cryptography	Node.js crypto (HMAC-SHA256)	Peppered identifier hashing (device ID, IP, MSISDN) and timing-safe webhook signature verification.
Mobile Client	Android SDK (Java 17 / API 26–35)	Native BiometricPrompt, NotificationManager, ExecutorService, SharedPreferences.
SecOps Web UI	HTML5, Vanilla CSS3, Modern ES6 JS	Zero-build-step embedded dashboard, responsive CSS grid, SVG animated gauges, real-time polling.
DevOps & CI/CD	Docker, Docker Compose, GitHub Actions	Multi-stage container builds, automated unit/integration test matrices (Node 20/22, Gradle 8.13).

6 Implementation Plan

The roadmap was executed across six engineering phases, ensuring complete end-to-end integration and rigorous verification:

Phase 1: Code Modernization & Architectural Foundation (Completed)

- Un-minified, formatted, and refactored backend into modular ES files (config.mjs, logger.mjs, crypto.mjs).
- Implemented base FraudRiskEngine interface and RuleBasedRiskEngine with 24h temporal correlation.

Phase 2: Database Layer & Persistence Abstraction (Completed)

- Defined production schema in 001_fraud_risk.sql covering events, risk scores, alerts, cases, and trusted devices.
- Implemented Repository pattern with InMemoryRiskRepository and PostgresRiskRepository.
- Added automated database migration runner (migrate.mjs) and docker-compose.yml.

Phase 3: Robust Backend Routing & Security Ingestion (Completed)

- Built modular routes: `events.mjs`, `users.mjs`, `alerts.mjs`, `cases.mjs`, `security.mjs`, `simulation.mjs`, `health.mjs`.
- Enforced HMAC-SHA256 signature validation via `X-Carrier-Signature` header.

Phase 4: Mobile Application Refactoring & Biometric Authentication (Completed)

- Integrated Android native `BiometricPrompt` for fingerprint verification and out-of-band customer confirmation.
- Upgraded `SecurityApiClient` with managed thread pool and offline demonstration fallback.
- Configured `versionCode 2`, `versionName '1.1.0'`, and permissions in `AndroidManifest.xml`.

Phase 5: Interactive SecOps Web Dashboard & Attack Simulator (Completed)

- Created embedded web application under `backend/public/` (`index.html`, `styles.css`, `app.js`).
- Built interactive SVG risk gauge, multi-stage ATO attack stepper, and fraud case management actions.

Phase 6: CI/CD Automation & Quality Assurance (Completed)

- Configured GitHub Actions workflows (`backend-ci.yml` and `android-apk.yml`).
- Executed 26 automated unit and integration tests with 100% pass rate.

7 Verification & Acceptance Matrix

VERIFICATION CRITERIA	TARGET BEHAVIOR	RESULT
Single SIM Swap Alert	Produces score 30 (MEDIUM) with warning banner; does not lock user out	PASSED
Escalated ATO Attack	SIM Swap + New Device + Password Reset + Beneficiary + Wire = Score 100 (CRITICAL)	PASSED
Temporal Expiration	Events older than 24 hours are excluded from active score calculation	PASSED
Hardware Biometrics	Native Android <code>BiometricPrompt</code> scans fingerprint before clearing alert	PASSED
SecOps Dashboard	Serves live SVG gauges, attack stepper, and cases at <code>http://localhost:3000/</code>	PASSED
Automated Test Suite	26 unit and integration test cases across risk engine, API, and dashboard	26 / 26 PASSED